

Writeup: Vulnerability

Explorando la Vulnerabilidad en Protocolos Críticos para la Seguridad Informática

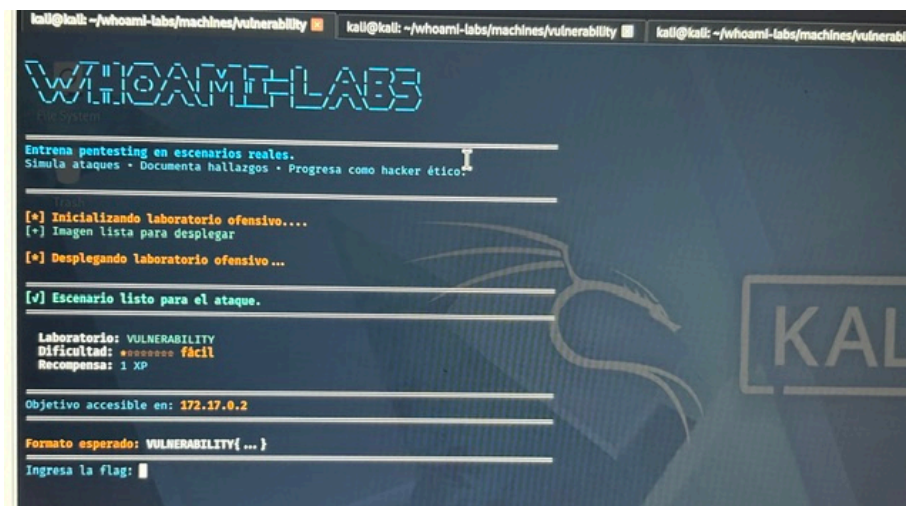
Enumeración SMB/NetBio

Plataforma	Whoami-labs.com
Máquina	Vulnerability
IP Objetivo	172.17.0.2
Puertos analizados	139/tcp (netbios-ssn), 445/tpc (netbios-ssn)
Servicio identificados	Samba smbd 3.0.20 Debian
Categoría	Enumeración de servicios / SMB Null Session
Dificultad	Baja
Fecha	Septiembre 06, 2026

¿Qué es SMB y NetBios?

SMB (Server Message Block): Es un protocolo de red utilizado principalmente para compartir archivos e impresoras en redes locales. SMB permite a las aplicaciones en una computadora leer y escribir en archivos y solicitar servicios de programas de servidor en una red.

NetBios (Network Basic Input/Output System): Es un conjunto de servicios de red que permite que las computadoras en una red local se comuniquen entre sí. Aunque NetBios no es un protocolo estrictamente hablando, se utiliza en conjunto con otros protocolos para proporcionar funcionalidad de red.



1. Reconocimiento inicial

Se realizó un escaneo de puertos dirigidos a los servicios NetBios/SMB, ya identificados los puertos como abiertos.

```
(kali@kali)~/.whoami-labs/machines/vulnerability
$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-06 08:30 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: DA:AE:05:72:FC:FB (Unknown)

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: vulnerability
|   NetBIOS computer name:
|   Domain name:
|   FQDN: vulnerability
|   System time: 2026-09-06T08:30:40-04:00
|_ clock-skew: mean: 1h59m59s, deviation: 2h49m42s, median: 0s
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: VULNERABILITY, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.20 seconds
```

```
(kali@kali)~/.whoami-labs/machines/vulnerability
$ nmap -p 139,445 -sV -sC 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-06 08:41 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000054s latency).
PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: DA:AE:05:72:FC:FB (Unknown)

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: vulnerability
|   NetBIOS computer name:
|   Domain name:
|   FQDN: vulnerability
|   System time: 2026-09-06T08:42:08-04:00
|_ nbstat: NetBIOS name: VULNERABILITY, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: 2h00m00s, deviation: 2h49m43s, median: 0s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.84 seconds
```

Este escaneo confirma que el servicio es Samba en una versión antigua y específica: 3.0.20. Además, la firma de mensajes SMB está deshabilitada, lo cual no es la causa de este hallazgo, pero es una mala práctica de configuración adicional

2. Búsqueda de vulnerabilidades conocidas

Al tratarse de una versión específica y antigua de Samba, se consultó la base de datos local de exploits.

Esta versión de Samba es vulnerable a CVE-2007-2447, un fallo que permite ejecutar comandos en el sistema sin necesidad de autenticarse, abusando de una función de mapeo de nombres de usuario. Se identificó como posible vector, pero antes de explotarlo se optó por enumerar los recursos compartidos disponibles.

3. Enumeración de recursos compartidos (shares)

Se listaron los shares disponibles con una sesión anónima (null session)

```
kali@kali: ~/whoami-labs/machines/vulnerability
(kali@kali)-[~/whoami-labs/machines/vulnerability]
$ smbclient -L //172.17.0.2/public -N
Anonymous login successful

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
tmp            Disk      oh noes!
opt            Disk
IPC$           IPC       IPC Service (vulnerability server (Samba 3.0.20-Debian))
ADMIN$         IPC       IPC Service (vulnerability server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

Server          Comment
-----
Workgroup       Master
WORKGROUP       VULNERABILITY
```

El acceso anónimo (-N) funcionó sin restricciones, lo que ya es un hallazgo de seguridad en sí mismo. El share tmp llamó la atención por su comentario "oh noes!", una pista fuera de lo habitual estándar de Samba.

4. Acceso al share y localización de la flag

Se accedió al share tmp de forma anónima y se exploró su contenido.

```
(kali@kali)-[~/whoami-labs/machines/vulnerability]
$ smbclient //172.17.0.2/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0 Sun Sep  6 08:45:53 2026
..               DR          0 Sun Sep  6 08:28:47 2026
.ICE-unix        DH          0 Sat Jan 27 21:08:08 2018
.X11-unix        DH          0 Sun Jan 28 00:14:49 2018
share            DR          0 Fri Feb 20 19:49:04 2026
826.jsvc_up      R           0 Sun Jan 28 01:08:40 2018
810.jsvc_up      R           0 Sat Jan 27 21:54:31 2018
1582.jsvc_up     R           0 Sat Jan 27 22:01:49 2018
1823.jsvc_up     R           0 Sat Jan 27 20:57:44 2018

82083148 blocks of size 1024. 42527164 blocks available
smb: \> cd share
smb: \share\> ls
.                DR          0 Fri Feb 20 19:49:04 2026
..               D           0 Sun Sep  6 08:45:53 2026
flag.txt         R           45 Fri Feb 20 19:49:04 2026

82083148 blocks of size 1024. 42527164 blocks available
smb: \share\> get flag.txt
getting file \share\flag.txt of size 45 as flag.txt (43.9 KiloBytes/sec) (average 43.9 KiloBytes/sec)
smb: \share\> exit
```

Dentro de tmp había un subdirectorio llamado share que contenía directamente el archivo flag.txt, accesible sin ningún tipo de autenticación. No fue necesario explotar la vulnerabilidad de comando remoto (CVE-2007-2447) para completar el objetivo del laboratorio.

```
(kali@kali)-[~/whoami-labs/machines/vulnerability]
$ cat flag.txt
cat: flag.txt: No such file or directory

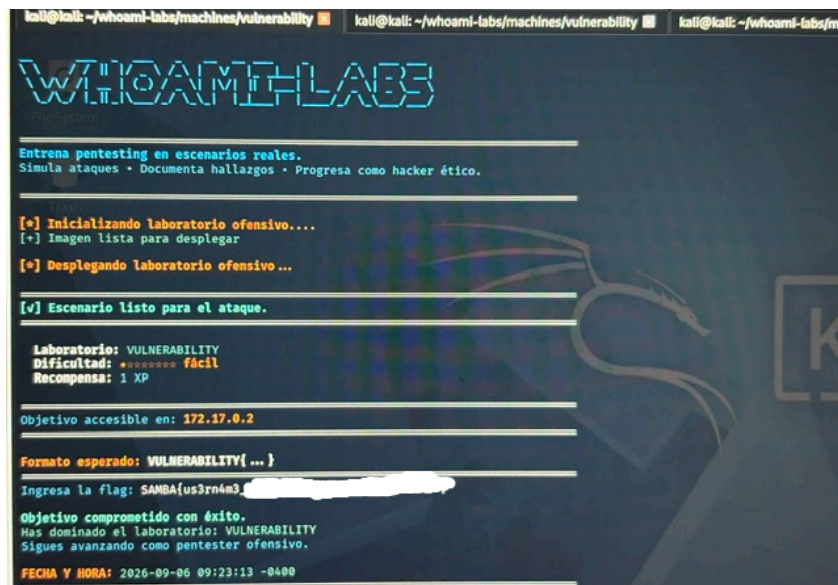
(kali@kali)-[~/whoami-labs/machines/vulnerability]
$ cat flag.txt
SAMBA{us3rn4m3_m4p_5[REDACTED]}
```


5. Conclusión

El laboratorio evidenció una configuración insegura del servicio Samba: el acceso anónimo (null session) estaba habilitado sin restricciones, permitiendo listar y navegar libremente los recursos compartidos del servidor. Aunque el reconocimiento inicial reveló una vulnerabilidad crítica de ejecución remota de comandos (CVE-2007-2447) asociada a la versión de Samba instalada, el objetivo del laboratorio se alcanzó por una vía más simple: la exposición directa de un archivo sensible (flag.txt) en un share accesible sin autenticación.

Teniendo como resultado la flag mediante enumeración de shares SMB con sesión anónima, sin necesidad de explotación remota.

La enumeración SMB/NetBios es un componente vital en la evaluación de la seguridad de una red. Comprender cómo funcionan estos protocolos y cómo se pueden proteger es crucial para mitigar posibles riesgos de seguridad. Implementar medidas de seguridad adecuadas puede ayudar a prevenir accesos no autorizados y proteger la integridad de los datos en la red.



```
kali@kali: ~/whoami-labs/machines/vulnerability | kali@kali: ~/whoami-labs/machines/vulnerability | kali@kali: ~/whoami-labs/machines/vulnerability
WTHOAMI-LABS
Entrena pentesting en escenarios reales.
Simula ataques • Documenta hallazgos • Progresa como hacker ético.

[*] Inicializando laboratorio ofensivo...
[+] Imagen lista para desplegar
[*] Desplegando laboratorio ofensivo...

[v] Escenario listo para el ataque.

Laboratorio: VULNERABILITY
Dificultad: ***** fácil
Recompensa: 1 XP

Objetivo accesible en: 172.17.0.2

Formato esperado: VULNERABILITY{ ... }
Ingresa la flag: SMB(us3rn4m3...)

Objetivo comprometido con éxito.
Has dominado el laboratorio: VULNERABILITY
Sigues avanzando como pentester ofensivo.

FECHA Y HORA: 2026-09-06 09:23:13 -0400
```

- **Nmap:** Un escáner de puertos ampliamente utilizado que puede detectar servicios SMB activos en una red.

Comandos Básicos

- **smbclient:** Una utilidad de línea de comandos para acceder a recursos compartidos SMB.
- **nbtstat:** Un comando utilizado en sistemas Windows para mostrar estadísticas de NetBios y resolver nombres NetBios.